Conservation et préparation d'archives - proposition à valider

Décision et état réel

Le choix de projet est : 24 mois pour les comptes inactifs, 12 mois après réception pour Contact, 6 mois après événement pour les journaux et 30 jours minimum pour les sauvegardes locales dédiées. Le responsable du traitement doit vérifier et valider ces durées, les finalités, bases légales, habilitations et procédures avant utilisation réelle. Ce document n'est pas un avis juridique. Le projet est une maquette : une commande simulée n'est pas automatiquement un document comptable. L'article L.123-22 du Code de commerce prévoit dix ans pour les documents comptables et pièces justificatives concernés, **pas pour tous les comptes ou toutes les commandes**. Un contentieux réel ou une demande de droits peut justifier une conservation distincte, limitée et réexaminée ; une instruction de gel documentée prime sur une suppression programmée.

[!] Ce qui existe : une purge CLI simulée par défaut de comptes inactifs **sans commande**, une maintenance séparée de `db_init.php` pour Contact, journal JSON et sauvegardes locales explicitement identifiées, et un outil manuel de copies chiffrées. Les comptes avec commande restent en clair dans la base active et visibles par les parcours existants ; une copie chiffrée ne constitue **pas** à elle seule leur archivage intermédiaire. La suppression des comptes avec commandes terminées demandée pour cette maquette n'est pas implémentée : le déclencheur SQL interdit la suppression des commandes validées et celui des lignes restaure le stock. Les contourner détruirait des garanties métier ; il faut une procédure dédiée transactionnelle, sécurisée et testée, avec validation d'absence d'obligation ou de gel par dossier. Rien n'est installé ni exécuté sur LineServ et aucun cron n'est activé.

Tableau proposé (non validé et non automatisé sauf mention)

Catégorie	Finalité et durée proposées	Échéance et actions à valider
Compte actif	24 mois après la dernière action de la personne ; la mise à jour de la connexion authentifiée n'est qu'un indicateur partiel.	Purge existante : seuls les comptes sans commande et aux dates fiables, avec marge de deux jours ; examen manuel de tout autre cas et des actions non reliées. Informer avant suppression selon procédure validée.

Commandes et comptes associés	En base active durant la relation et les opérations en cours. Ensuite, ne conserver en archive intermédiaire que les éléments nécessaires à une obligation ou à un contentieux identifié, avec échéance justifiée pour chaque dossier ; les seules pièces comptables réellement concernées peuvent relever de dix ans.	[!] Aucun transfert restreint opérationnel : développer et éprouver extraction minimale, exclusion des commandes en cours, contrôle concurrent et retrait sûr des originaux, y compris clés étrangères, historique et tous les parcours. N'effacer ni preuve nécessaire ni stock par effet de bord. Vérifier le fuseau d'origine des dates historiques et celui des écritures SQL externes avant utilisation des dates.
Messages Contact (`var/log/contact.jsonl`)	Choix pour la maquette : 12 mois après réception, sous réserve que chaque demande ait été traitée et qu'aucune conservation particulière ne soit nécessaire.	La maintenance supprime les entrées de plus de 12 mois aux dates valides après validation explicite globale ; elle ne connaît ni clôture, ni obligation ni gel par message. Si une entrée doit être conservée ou est en cours, ne pas exécuter la catégorie avant traitement séparé. Dates invalides conservées. Le fichier n'est pas automatiquement associé à un compte.
Journaux JSON historiques et journaux de sécurité	Choix pour le journal JSON applicatif : 6 mois glissants après l'événement ; autres journaux à inventorier par finalité. Éviter données et snapshots personnels inutiles.	La maintenance ne concerne que `db.jsonl` (ou `journal.jsonl` du magasin JSON configuré). Les lignes aux dates invalides sont conservées. Aucun gel par entrée : s'il existe une preuve à conserver, ne pas exécuter la catégorie. Autres journaux, traces SQL et copies à traiter séparément ; les anciennes entrées peuvent contenir des données personnelles.
Sauvegardes, exports et copies hors ligne	Choix pour les sauvegardes locales identifiées : au moins 30 jours et conservation des deux plus récentes ; à adapter aux contraintes de restauration, avec chiffrement et accès réservés. Ne pas confondre sauvegarde et archive légale.	Seul le dossier dédié explicitement configuré est traité, et uniquement les fichiers achevés respectant le format indiqué ci-dessous. Les deux sauvegardes reconnues les plus récentes sont préservées, sans garantie de validité. Inventorier et traiter séparément les copies hébergeur et hors ligne, tester la restauration et répercuter les suppressions après restauration.
Journal de consultation des archives	Proposition : conserver 12 mois, sauf besoin de preuve justifié et validé ; ne journaliser ni contenu, ni nom, ni e-mail.	[!] `acces.jsonl` est local à la machine de restitution ; sa rétention, centralisation protégée et revue sont à organiser. Un UID n'identifie pas une personne si un compte est partagé.

Ces choix ne créent aucun délai légal et ne doivent pas être activés sans validation, registre des traitements et information des personnes mis à jour. La purge d'une source n'efface pas automatiquement les fichiers temporaires, journaux, caches, snapshots ou sauvegardes. Les droits d'accès et d'effacement doivent aussi couvrir les archives et leurs éventuelles exceptions

légales.

Maintenance distincte dans `db_init.php`

`php scripts/db_init.php --nettoyage --help` affiche les catégories. Cette voie ne recrée jamais la base et ne dépend pas de `--yes`. Pour chaque catégorie `comptes`, `contact`, `journaux` ou `sauvegardes`, la commande est une simulation par défaut. L'exécution nécessite **ensemble** `--executer --validation-absence-gel` ; cette attestation signifie que le responsable a contrôlé tous les éléments concernés et confirmé qu'aucune durée, obligation, demande ou gel ne s'oppose à leur suppression. Le programme ne sait pas identifier ces exceptions ni exclure un seul élément sur demande : en cas de doute, ne pas exécuter la catégorie. Les bilans sont des nombres, sans contenu personnel. Un fichier de verrou vide peut être créé même en simulation.

- `comptes` réutilise la purge existante ; les comptes avec commandes restent exclus et signalés. Cette opération ne traite ni les journaux, ni les sauvegardes.
- `contact` vise uniquement `var/log/contact.jsonl`, 12 mois après `date` ; `journaux` vise uniquement `var/journal/db.jsonl` ou `journal.jsonl` du `DATA_PATH` JSON, 6 mois après `at`. Les dates absentes, futures, mal formées ou les lignes JSON corrompues restent conservées. Lignes de plus de 1 Mio ou erreurs de lecture/écriture : arrêt sans remplacement. Le nouveau fichier est privé (0600), et l'opération doit être lancée sous l'UID propriétaire du journal avec l'extension PHP POSIX. Les nouvelles écritures utilisent un verrou stable commun ; avant mise en service, arrêter les anciennes versions et redémarrer tous les travailleurs : les anciens processus et écritures externes ne respectent pas ce verrou. Prévoir une fenêtre sans écritures externes ; ne pas utiliser des systèmes de fichiers où `flock` ou `rename` ne sont pas fiables. Une interruption peut laisser un fichier temporaire privé `.rotation-*` contenant des données : l'inventorier et l'éliminer selon la procédure, hors activité concurrente. La rotation n'efface pas les autres copies.
- `sauvegardes` exige `NETTOYAGE_SAUVEGARDES` dans `.env` : chemin absolu d'un dossier **dédié**, privé (0700), appartenant au compte CLI, hors dépôt et de tous les webroots et dossiers de données. Le dossier doit contenir le fichier privé `.minishop-sauvegardes` dont le contenu exact est `MINISHOP_BACKUPS_V1` suivi d'un saut de ligne. Ne pas y placer d'autres données. Les fichiers achevés doivent s'appeler `minishop-AAAAMMJJThhmmssZ-` suivi de 32 chiffres hexadécimaux minuscules et `.backup` ; la date est en UTC. Le script ne produit pas ces sauvegardes. Il ignore les autres noms, liens, dates invalides et fichiers avec plusieurs liens ; seuls les fichiers de plus de 30 jours **selon leur nom et leur date de modification** sont éligibles, en conservant au moins deux noms reconnus les plus récents. Il ne vérifie ni chiffrement, intégrité, complétude ni restauration : l'exploitant doit le faire avant suppression. Les créations et restaurations doivent être arrêtées durant la rotation ; le verrou local ne protège pas les outils externes. Une erreur en cours peut laisser une suppression partielle : contrôler le bilan et réexaminer avant reprise.

Les copies de l'hébergeur, snapshots, binlogs, archives chiffrées, journaux de consultation, caches, données hors des chemins visés et fichiers temporaires ne sont pas supprimés. Aucun planificateur n'est installé ; l'installation automatique ne doit être envisagée qu'après validation, sauvegarde et essai de restauration. Ne jamais utiliser `db_init.php --yes` sur une base existante pour faire de la rétention : cette option recrée la base entière.

Essai reproductible sur sauvegardes fictives uniquement

Depuis une machine Linux/PHP avec extension POSIX. Ce bloc crée puis supprime uniquement son propre dossier temporaire ; il ne lit ni ne supprime les sauvegardes réelles.

```
cd /home/jojokes/Documents/BUT/Projet/s302
(
set -eu
D=$(mktemp -d)
trap 'rm -rf "$D"' EXIT
mkdir -m 700 "$D/sauvegardes"
printf 'MINISHOP_BACKUPS_V1\n' > "$D/sauvegardes/.minishop-sauvegardes"
for AN in 2001 2002 2003; do
  F="$D/sauvegardes/minishop-${AN}0101T000000Z-aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa.backup"
  printf 'copie fictive\n' > "$F"
  touch -d "${AN}-01-01 UTC" "$F"
done
export NETTOYAGE_SAUVEGARDES="$D/sauvegardes" MINISHOP_ENV_FILE="$D/inexistant.env"
php scripts/db_init.php --nettoyage sauvegardes
php scripts/db_init.php --nettoyage sauvegardes --executer --validation-absence-gel
)
```

Sortie attendue : `SIMULATION eligible=1 supprime=0 conserve=2`, puis `EXÉCUTION eligible=1 supprime=1 conserve=2`. Les commandes de maintenance par catégorie ne déclenchent pas l'installation SQL.

Outil manuel : copies chiffrées, pas transfert

`scripts/archive_restreinte.php` utilise les boîtes scellées libsodium (clé publique pour chiffrer ; clé privée pour déchiffrer), PHP CLI avec extensions `sodium` et `posix`, sous Linux/POSIX. Il refuse les répertoires dans le dépôt, ceux accessibles au groupe/autres ou dont le propriétaire n'est pas l'UID effectif, les fichiers source et clés sous forme de lien symbolique final, les clés invalides, fichiers existants et données de plus de **8 Mio**. Les copies et restitutions sont créées en 0600 ; les métadonnées (catégorie, justification et échéance) sont dans l'enveloppe chiffrée. Le nom aléatoire n'identifie pas la personne. Chaque commande de scellement sans `--executer` est une simulation ; elle lit néanmoins la source. Le scellement ne modifie ni ne supprime la source. Il ne garantit pas un instantané cohérent si la source est modifiée pendant la lecture : réaliser l'extraction sous maintenance ou depuis un instantané cohérent. Une interruption peut laisser un fichier chiffré incomplet, qui ne doit pas être utilisé.

La consultation exige un motif prédéfini et écrit d'abord, dans le répertoire privé de restitution, une entrée UTC avec UID et empreinte SHA-256 du fichier chiffré ; si le journal ne peut pas être écrit, aucune restitution n'est créée. L'événement signifie **restitution demandée**, pas qu'elle a réussi. Le fichier restitué est en clair : travailler sur un poste maîtrisé, empêcher sa sauvegarde/synchronisation non voulue et appliquer une procédure d'effacement appropriée. Le journal local est modifiable par son propriétaire ; il ne trace pas l'usage direct d'autres outils de déchiffrement. Prévoir un collecteur séparé protégé et une revue des accès pour une traçabilité fiable. Les boîtes scellées protègent la confidentialité et détectent la corruption, mais **n'authent**

ifient pas l'auteur : toute personne possédant la clé publique peut créer un fichier. Ne pas utiliser ce format seul comme preuve d'origine.

L'outil n'établit pas la nécessité légale, ne vérifie pas le contenu ni l'échéance après création, et ne supprime pas à échéance. La catégorie et la justification sont des déclarations de l'opérateur, pas des validations. Il est destiné aux petits fichiers préparés et minimisés ; aucun découpage automatique ni outil de sauvegarde volumineuse n'est fourni. Ne pas sceller toute la base au titre d'un seul client. Avant toute utilisation réelle : limiter les champs aux besoins justifiés, prévoir une sélection fiable et un registre séparé des échéances, accès et gels, désigner des personnes habilitées, établir un circuit d'accès ponctuel motivé et tester la restitution et la suppression dans un environnement jetable. Le répertoire doit être hors de **tous** les webroots, dépôts, synchronisations et sauvegardes non autorisées ; le script ne peut pas déterminer tous ces emplacements ni auditer les ACL, comptes privilégiés ou configurations d'hébergement. Vérifier ces aspects et les droits système séparément.

Générer la clé privée sur une machine de confiance distincte, non accessible au compte applicatif ; ne transférer que la clé publique vers le serveur de scellement. Stocker et sauvegarder la clé privée séparément, sous contrôle des personnes habilitées ; documenter rotation, perte et destruction des clés, et canal sécurisé de transfert des copies chiffrées. Une personne pouvant lire la clé privée peut contourner le programme et son journal. Ne pas placer de clé privée dans `.env`, le dépôt, les arguments, les journaux ou les artefacts CI.

Démonstration locale sans données réelles

À exécuter depuis le dépôt sur une machine Linux dotée de PHP, sodium et posix. Uniquement des données fictives ; la clé privée et la copie sont volontairement dans le même dossier temporaire **pour cette démonstration**, contrairement à l'organisation réelle. Le nettoyage ne concerne que ce répertoire temporaire créé par la commande.

```
cd /home/jojokes/Documents/BUT/Projet/s302
(
set -eu
D=$(mktemp -d)
trap 'rm -rf "$D"' EXIT
mkdir -m 700 "$D/cles" "$D/archives" "$D/sortie"
printf 'message fictif\n' > "$D/source.txt"
php scripts/archive_restreinte.php generer-cles --dossier "$D/cles"
php scripts/archive_restreinte.php sceller --source "$D/source.txt" --dossier "$D/archives" --cle-
publique "$D/cles/cle-publique.txt" --categorie contact --echeance 2099-01-01 --justification
droits
php scripts/archive_restreinte.php sceller --source "$D/source.txt" --dossier "$D/archives" --cle-
publique "$D/cles/cle-publique.txt" --categorie contact --echeance 2099-01-01 --justification
droits --executer
A=$(find "$D/archives" -name '*.msa' -type f -print -quit)
php scripts/archive_restreinte.php consulter --archive "$A" --cle-privee "$D/cles/cle-privee.txt"
--dossier-sortie "$D/sortie" --motif controle
R=$(find "$D/sortie" -name 'restitution-*.bin' -type f -print -quit)
cmp "$D/source.txt" "$R" && echo 'OK : restitution identique ; source inchangée'
test "$(wc -l < "$D/sortie/acces.jsonl")" -eq 1 && echo 'OK : une demande de restitution tracée'
```

```
)
```

Sortie attendue : création des clés, `SIMULATION`, création d'une copie chiffrée, restitution en clair, puis les deux lignes `OK`. Les noms aléatoires varient. `2099-01-01` est une date de test, **pas** une durée de conservation approuvée. L'exemple n'installe ni planification ni politique sur l'instance.

Références

• [CNIL - concilier durées de conservation et archives](https://www.cnil.fr/fr/comment-concilier-les-durees-de-conservation-et-les-archives) : tri, séparation, habilitations et traçabilité des consultations.

• [CNIL - questions-réponses activités commerciales](https://www.cnil.fr/fr/questions-reponses-sur-les-referentiels-relatifs-la-gestion-des-activites-commerciales-et-des) : deux ans d'inactivité pour un compte, par distinction avec la prospection.

• [CNIL - guide sécurité 2024](https://www.cnil.fr/sites/cnil/files/2024-03/cnil_guide_securite_personnelle_2024.pdf) : sécurité des sauvegardes, restauration, journalisation.

• [Code de commerce, article L.123-22](https://www.legifrance.gouv.fr/codes/article_lc/LEGIARTI000006219327/) ; [RGPD, articles 5 et 17](https://eur-lex.europa.eu/legal-content/FR/TXT/HTML/?uri=CELEX%3A32016R0679).